

BCSE320L	WEB APPLICATION SECURITY			L	T	P	C
				3	0	0	3
Pre-requisite	NIL			Syllabus version			
				1.0			
Course Objectives							
1. To study and practice fundamental techniques to develop secure web applications. 2. To identify web applications vulnerabilities and understand vulnerability management. 3. To assess web application security attacks and defence.							
Course Outcome							
After completion of this course, the student shall be able to:							
1. Understand security challenges and the need for Authentication and Authorization in web-based systems and applications. 2. Familiarize the Application Programming Interface analysis and vulnerability management of securing a web-based system. 3. Learn the web application hacking techniques and prevention solutions. 4. Apply the best practices of Secure Credentials, session management, and Security Automation in web applications. 5. Develop the best strategies to prevent XSS, CSRF, XXE, Injection, DOS attacks and Securing Third-Party Dependencies.							
Module:1	Web Application Reconnaissance			5 hours			
Information Gathering - Web Application Mapping - Structure of Modern Web Application: Modern Versus Legacy Web Applications, REST APIs, JavaScript Object Notation, Browser DOM, SPA Frameworks, Authentication and Authorization Systems, Web Servers, Server-Side Databases, Client-Side Data Stores.							
Module:2	Sub Domain and Application Programming Interface Analysis			7 hours			
Sub Domain: Multiple Applications per Domain - Browser's Built-In Network Analysis Tools - Search Engine Caches - Accidental Archives - Social Snapshots - Zone Transfer Attacks - Brute Forcing Subdomains and Dictionary Attacks - Application Programming Interface Analysis(API): Endpoint Discovery and Endpoint Shapes, Authentication Mechanisms.							
Module:3	Web Application Vulnerability			6 hours			
Detecting Client-Side and Server-Side Frameworks - Secure Versus Insecure Architecture Signals - Multiple Layers of Security - Adoption and Reinvention - Common Vulnerabilities and Exposures Database							
Module:4	Web Application Hacking			6 hours			
Cross-Site Scripting (XSS): XSS Discovery and Exploitation, Stored XSS, Reflected XSS, DOM-Based XSS, Mutation-Based XSS - Cross-Site Request Forgery (CSRF): Query Parameter Tampering, CSRF Against POST Endpoints - XML External Entity (XXE): Direct and Indirect XXE.							
Module:5	Web Application Attacks			6 hours			
SQL Injection - Code Injection - Command Injection - Denial of Service (DoS): regex DoS (ReDoS), Logical DoS Vulnerabilities, Distributed DoS - Exploiting Third-Party Dependencies.							
Module:6	Securing Web Applications			7 hours			
Defensive Software Architecture - Vulnerability Analysis and Management - Secure Sockets Layer and Transport Layer Security - Secure Credentials, Hash Credentials - Secure-Coding Anti-Patterns - Security Automation: static and dynamic analysis - Vulnerability Regression Testing - Bug Bounty Programs.							
Module:7	Vulnerability Management and Hacking Prevention			6 hours			
Common Vulnerability Scoring System - Defending Against attacks: XSS, CSRF, XXE							